# Informe de Corrección de Vulnerabilidades

Django Realworld Example App

Entrega 3: DevSecOps

## 1. Resumen

Se utilizó Trivy para realizar un escaneo de vulnerabilidades del sistema de archivos sobre las dependencias del proyecto. Se compararon dos estados del escaneo:

| Estado | Fuente de requirements.txt | Versión de Django | Vulnerabilidades encontradas |
|---|---|---|---|
| ANTES | Repositorio fuente original | 1.10.5 | 15 CVEs (3 CRÍTICAS, 4 ALTAS, 7 MEDIAS, 1 BAJA) |
| DESPUÉS | Rangos de versiones actualizados | 4.2.29 | 0 CVEs |

El repositorio original fijaba versiones de paquetes muy antiguas. La solución consistió en actualizar todas las dependencias a rangos de versiones modernas y seguras que se resuelven en versiones ya corregidas.

## 2. ANTES — Resultados completos del escaneo (Repositorio original)

**Paquetes escaneados:**

| Paquete | Versión |
|---|---|
| Django | 1.10.5 |
| PyJWT | 1.4.2 |
| djangorestframework | 3.4.4 |

**Total: 15 vulnerabilidades — UNKNOWN: 0, LOW: 1, MEDIUM: 7, HIGH: 4, CRITICAL: 3**

### 2.1 Django 1.10.5 — 12 CVEs

| CVE | Severidad | Título | Corregido en |
|---|---|---|---|
| **CVE-2019-19844** | CRÍTICA | Toma de control de cuenta mediante dirección de correo manipulada | 1.11.27, 2.2.9, 3.0.1 |
| **CVE-2020-7471** | CRÍTICA | Inyección SQL mediante StringAgg(delimiter) | 1.11.28, 2.2.10, 3.0.3 |
| **CVE-2025-64459** | CRÍTICA | Vulnerabilidad de inyección SQL | 4.2.26, 5.1.14, 5.2.8 |
| **CVE-2022-36359** | ALTA | Inyección de encabezados en FileResponse | 3.2.15, 4.0.7 |

| CVE | Severidad | Título | Corregido en |
|---|---|---|---|
| **CVE-2025-57833** | **ALTA** | Inyección SQL mediante alias de columna en FilteredRelation | 4.2.24, 5.1.12, 5.2.6 |
| **CVE-2025-64458** | **ALTA** | Vulnerabilidad de denegación de servicio en Windows | 4.2.26, 5.1.14, 5.2.8 |
| **CVE-2017-12794** | **MEDIA** | XSS en la página técnica de depuración 500 | 1.10.8, 1.11.5 |
| **CVE-2017-7233** | **MEDIA** | Redirección abierta + XSS mediante URLs numéricas | 1.10.7, 1.9.13 |
| **CVE-2017-7234** | **MEDIA** | Redirección abierta en django.views.static.serve() | 1.10.7, 1.9.13 |
| **CVE-2021-33203** | **MEDIA** | Traversal de directorios mediante admindocs | 2.2.24, 3.1.12, 3.2.4 |
| **CVE-2024-45231** | **MEDIA** | Enumeración de correos de usuarios mediante respuesta de recuperación de contraseña | 4.2.16, 5.0.9, 5.1.1 |
| **CVE-2025-48432** | **MEDIA** | Vulnerabilidad de inyección de ruta | 4.2.22, 5.1.10, 5.2.2 |

### 2.2 PyJWT 1.4.2 — 1 CVE

| CVE | Severidad | Título | Corregido en |
|---|---|---|---|
| **CVE-2017-11424** | **ALTA** | Manejo incorrecto de claves públicas codificadas en PEM | 1.5.1 |

### 2.3 djangorestframework 3.4.4 — 2 CVEs

| CVE | Severidad | Título | Corregido en |
|---|---|---|---|
| **CVE-2020-25626** | **MEDIA** | XSS en el visor de API | 3.11.2 |
| **CVE-2024-21520** | **BAJA** | XSS mediante break_long_headers | 3.15.2 |

## 3. Vulnerabilidades críticas seleccionadas para corrección

Se priorizaron dos vulnerabilidades CRÍTICAS para su remediación.

### CVE-2019-19844 — Toma de control de cuentas en Django mediante correo manipulado

| Campo | Detalle |
|---|---|
| Paquete | Django 1.10.5 |
| Severidad | CRÍTICA |
| Puntuación CVSS | 9.8 |

| Campo | Detalle |
|---|---|
| Corregido en | Django 1.11.27, 2.2.9, 3.0.1 |
| Corrección aplicada | Actualización a Django 4.2.29 (mediante Django>=4.2,<5.0) |
| Vector de ataque | Red — no requiere autenticación |
| Referencia | https://avd.aquasec.com/nvd/cve-2019-19844 |

**Descripción:**

El formulario de recuperación de contraseña de Django realizaba una comparación no sensible a mayúsculas/minúsculas entre el correo ingresado y los correos almacenados en el sistema, pero enviaba el enlace de recuperación al correo almacenado. Un atacante podía crear un correo como VICTIM@example.com para recibir un token de recuperación destinado a otro usuario, permitiendo tomar control completo de la cuenta sin autenticación previa.

### CVE-2020-7471 — Inyección SQL en Django mediante delimitador de StringAgg

| Campo | Detalle |
|---|---|
| Paquete | Django 1.10.5 |
| Severidad | CRÍTICA |
| Puntuación CVSS | 9.8 |
| Corregido en | Django 1.11.28, 2.2.10, 3.0.3 |
| Corrección aplicada | Actualización a Django 4.2.29 (mediante Django>=4.2,<5.0) |
| Vector de ataque | Red — explotable mediante entrada no sanitizada en consultas ORM |
| Referencia | https://avd.aquasec.com/nvd/cve-2020-7471 |

**Descripción:**

La función django.contrib.postgres.aggregates.StringAgg no sanitizaba correctamente el parámetro delimiter. Un atacante que pudiera controlar este parámetro (por ejemplo, mediante entrada del usuario pasada a una consulta ORM) podría inyectar SQL arbitrario, permitiendo leer, modificar o eliminar datos de la base de datos.

## 4. Remediación aplicada

Todas las vulnerabilidades se resolvieron actualizando el archivo requirements.txt, pasando de versiones heredadas fijadas a rangos de versiones modernas y mantenidas.

### Antes (requirements.txt — repositorio original)

```
Django==1.10.5
djangorestframework==3.4.4
PyJWT==1.4.2
```

### Después (requirements.txt — actualizado)

```
Django>=4.2,<5.0
django-cors-headers>=4.3,<5.0
django-extensions>=3.2,<4.0
djangorestframework>=3.14,<4.0
PyJWT>=2.8,<3.0
pytest>=7.4
pytest-django>=4.7
coverage>=7.3
```

# 5. DESPUÉS — Resultados del escaneo (Dependencias actualizadas)

## Comando del escáner

```
pip install -r requirements.txt
pip freeze > requirements.txt
trivy fs --scanners vuln,secret,misconfig .
```

## Resultado

| Target | Tipo | Vulnerabilidades | Secrets | Misconfigurations |
|---|---|---|---|---|
| requirements.txt | pip | 0 | - | - |

**Las 15 vulnerabilidades fueron resueltas. 0 vulnerabilidades detectadas.**

# 6. Resumen final

| Métrica | Antes | Después |
|---|---|---|
| Vulnerabilidades totales | 15 | 0 |
| CRÍTICAS | 3 | 0 |
| ALTAS | 4 | 0 |
| MEDIAS | 7 | 0 |
| BAJAS | 1 | 0 |
| Versión de Django | 1.10.5 | 4.2.29 |
| Versión de PyJWT | 1.4.2 | 2.9.0 |
| Versión de djangorestframework | 3.4.4 | 3.15.2 |

Las dos vulnerabilidades CRÍTICAS seleccionadas (CVE-2019-19844 y CVE-2020-7471) fueron resueltas al actualizar Django desde 1.10.5 a 4.2.29. Ambas vulnerabilidades han sido corregidas en las versiones oficiales de Django desde 2020 y no representan ningún riesgo en la versión actualizada.